

# Security Lab GRC Documentation

## CIS Critical Security Controls v8.1.2



Created By: Paul Leone  
April 4, 2026



# Table of Contents

|                                                                             |    |
|-----------------------------------------------------------------------------|----|
| CIS Critical Security Controls v8.1.2 .....                                 | 2  |
| Version 2.0 — Change Log (from v1.0, January 2026) .....                    | 2  |
| CIS Control 1: Inventory and Control of Enterprise Assets .....             | 6  |
| CIS Control 2: Inventory and Control of Software Assets .....               | 7  |
| CIS Control 3: Data Protection .....                                        | 8  |
| CIS Control 4: Secure Configuration of Enterprise Assets and Software ..... | 10 |
| CIS Control 5: Account Management .....                                     | 12 |
| CIS Control 6: Access Control Management .....                              | 14 |
| CIS Control 7: Continuous Vulnerability Management .....                    | 15 |
| CIS Control 8: Audit Log Management .....                                   | 17 |
| CIS Control 9: Email and Web Browser Protections .....                      | 19 |
| CIS Control 10: Malware Defenses .....                                      | 20 |
| CIS Control 11: Data Recovery .....                                         | 21 |
| CIS Control 12: Network Infrastructure Management .....                     | 22 |
| CIS Control 13: Network Monitoring and Defense .....                        | 24 |
| CIS Control 14: Security Awareness and Skills Training .....                | 26 |
| CIS Control 15: Service Provider Management .....                           | 27 |
| CIS Control 16: Application Software Security .....                         | 28 |
| CIS Control 17: Incident Response Management .....                          | 29 |
| CIS Control 18: Penetration Testing .....                                   | 31 |
| Summary of Compliance Status .....                                          | 31 |
| Version History .....                                                       | 32 |

# CIS Critical Security Controls v8.1.2

## Document Control:

|                |                  |
|----------------|------------------|
| Version:       | 2.0              |
| Last Updated:  | April 2026       |
| Owner:         | Paul Leone       |
| Prior Version: | 1.1 — March 2026 |



## Version 2.0 — Change Log (from v1.1, March 2026)

The table below lists all safeguards updated in this revision. Cloud workload content has been integrated directly into the Implementation and Notes columns of each affected safeguard rather than held in a separate section.

| Control          | Safeguard  | Change                                                                                                                                                                             | Impact on Status                |
|------------------|------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------|
| <b>Control 1</b> | <b>1.1</b> | Inventory expanded to include 6 cloud nodes (AWS EC2 ×2, GCP Compute ×2, Azure VM ×2) tracked in Checkmk, Wazuh, and PatchMon via Tailscale.                                       | Compliant — no change to status |
| <b>Control 1</b> | <b>1.2</b> | Weekly cloud asset review process documented; Tailscale admin console and cloud-provider consoles (AWS EC2, GCP Compute, Azure VM) added as authoritative cloud inventory sources. | Gap partially addressed         |
| <b>Control 1</b> | <b>1.3</b> | Cloud VPC/VNet subnets included in active discovery scope; cloud-native network discovery (VPC flow logs, NSG flow logs) documented as supplemental discovery sources.             | Compliant — no change to status |
| <b>Control 2</b> | <b>2.1</b> | PatchMon extended to 4 Linux cloud nodes; Windows cloud nodes (AWS, Azure) tracked via WSUS; cloud node packages included in 5,000+ package count.                                 | Compliant — strengthened        |
| <b>Control 2</b> | <b>2.2</b> | PatchMon EOL tracking extended to cloud node OS versions; AWS Amazon Linux 2 EOL monitoring added; Azure/GCP image currency tracked.                                               | Compliant — no change to status |
| <b>Control 2</b> | <b>2.4</b> | PatchMon and Wazuh agent-based inventory extended to all cloud nodes; automated software inventory now covers on-premises and cloud workloads.                                     | Compliant — strengthened        |
| <b>Control 3</b> | <b>3.1</b> | Cloud data management scope added: AWS S3 (CloudTrail logs, SSE), GCP Cloud Storage                                                                                                | Compliant — strengthened        |

|                  |             |                                                                                                                                                                                     |                                         |
|------------------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------|
|                  |             | (default encryption), Azure Log Analytics (homelab-log, 90-day retention).                                                                                                          |                                         |
| <b>Control 3</b> | <b>3.2</b>  | Cloud data inventory documented: S3 buckets, GCS buckets, Log Analytics workspace, cloud node EBS/Managed Disk volumes.                                                             | Compliant — strengthened                |
| <b>Control 3</b> | <b>3.3</b>  | Cloud access controls added: AWS IAM instance profiles (least-privilege), GCP service account minimal roles, Azure RBAC; Tailscale ACL policy governs node-to-node access.          | Compliant — strengthened                |
| <b>Control 3</b> | <b>3.4</b>  | Cloud-native log retention documented: AWS CloudTrail to S3, GCP Audit Logs, Azure Log Analytics (90 days), all matching on-premises SIEM retention policy.                         | Compliant — strengthened                |
| <b>Control 3</b> | <b>3.8</b>  | Cloud data flow documentation added: Tailscale mesh routing, VPC/VNet topology, Wazuh agent telemetry paths, cloud-to-SIEM forwarding paths documented.                             | Partial — scope improved                |
| <b>Control 3</b> | <b>3.10</b> | Cloud encryption in transit added: Tailscale WireGuard (ChaCha20-Poly1305) for all management paths; SSH AES-256-GCM for Linux cloud nodes.                                         | Compliant — strengthened                |
| <b>Control 3</b> | <b>3.11</b> | Cloud encryption at rest added: AWS S3 SSE, GCP persistent disk default encryption, Azure Managed Disk encryption, Azure Log Analytics encryption at rest.                          | Compliant — strengthened                |
| <b>Control 4</b> | <b>4.1</b>  | Cloud configuration baselines added: Ansible hardening playbooks applied to all Linux cloud nodes; Azure ARM template version-controlled; GCP/AWS instance config managed via Git.  | Needs documentation — cloud scope added |
| <b>Control 4</b> | <b>4.2</b>  | Cloud network device hardening added: AWS Security Group rules documented; GCP VPC firewall policy (17 rules, Threat Intelligence blocking) documented; Azure NSG rules documented. | Compliant — strengthened                |
| <b>Control 4</b> | <b>4.4</b>  | Cloud host firewalls confirmed: AWS Security Groups and GCP/Azure NSG firewall policies serve as host-level firewall controls for all cloud instances.                              | Compliant — strengthened                |
| <b>Control 4</b> | <b>4.6</b>  | Cloud management access: all SSH/RDP restricted to homelab subnets via provider-native firewall rules; Tailscale WireGuard                                                          | Compliant — strengthened                |



|                  |            |                                                                                                                                                                                                          |                          |
|------------------|------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|
|                  |            | mandatory for cloud management paths; no public ports.                                                                                                                                                   |                          |
| <b>Control 5</b> | <b>5.1</b> | Cloud node accounts included in inventory: service accounts (AWS IAM, GCP), Entra ID accounts (Azure). Wazuh agent tracks user accounts on all cloud nodes.                                              | Compliant — strengthened |
| <b>Control 6</b> | <b>6.3</b> | Cloud services protected by provider-native controls: AWS Security Groups restrict all external inbound; GCP Cloud Armor WAF protects GCP workloads; Azure NSG enforces explicit allow-list.             | Compliant — strengthened |
| <b>Control 6</b> | <b>6.4</b> | Cloud remote access: Tailscale WireGuard mesh VPN provides zero-trust remote access to all cloud nodes; no traditional VPN concentrator; ACL-enforced per node.                                          | Compliant — strengthened |
| <b>Control 7</b> | <b>7.3</b> | Cloud node OS patching: WSUS manages Windows cloud nodes (AWS, Azure); Ansible update_linux_hosts.yml patches Linux cloud nodes via Tailscale; Critical <72h MTTR maintained.                            | Compliant — strengthened |
| <b>Control 7</b> | <b>7.5</b> | Cloud vulnerability scanning added: Wazuh CIS SCA daily on all 8 cloud nodes; AWS Inspector (EC2); GCP SCC vulnerability assessment; Azure Defender for Cloud recommendations.                           | Compliant — strengthened |
| <b>Control 7</b> | <b>7.6</b> | Cloud external scanning: AWS Inspector external-facing assessment; GCP SCC external threat detection; Azure Defender for Cloud internet-exposed resource assessment.                                     | Compliant — strengthened |
| <b>Control 7</b> | <b>7.7</b> | Cloud remediation SLA enforced: PatchMon tracks cloud node CVEs; Critical <72h, High <7d MTTR maintained across cloud scope; Ansible emergency patching via Tailscale.                                   | Compliant — strengthened |
| <b>Control 8</b> | <b>8.2</b> | Cloud audit log sources added: AWS CloudTrail (all mgmt events to S3 with SSE), GCP Admin Activity logs (always-on), Azure Activity Log + Monitor; Wazuh agent forwards cloud endpoint events to Splunk. | Compliant — strengthened |
| <b>Control 8</b> | <b>8.9</b> | Cloud log forwarding: Wazuh Universal Forwarder from cloud nodes to on-premises Splunk; cloud-native logs retained in provider storage (S3, GCS, Log Analytics) with matching 90-day retention.          | Compliant — strengthened |

|                   |             |                                                                                                                                                                                                                   |                          |
|-------------------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|
| <b>Control 12</b> | <b>12.1</b> | Cloud network infrastructure included: AWS VPC, GCP VPC, Azure VNet patch/version currency tracked; Tailscale client updated via package manager on cloud nodes.                                                  | Compliant — strengthened |
| <b>Control 12</b> | <b>12.2</b> | Cloud network architecture documented: Tailscale mesh routing tables, VPC/VNet CIDR allocations, per-provider subnet router configurations, cloud-to-on-premises routing tables added.                            | Compliant — strengthened |
| <b>Control 12</b> | <b>12.4</b> | Cloud network diagrams added: Tailscale node inventory (9 nodes), VPC/VNet topology, subnet router advertisement table, cloud ACL policy documented.                                                              | Compliant — strengthened |
| <b>Control 12</b> | <b>12.7</b> | Cloud remote device VPN: all cloud nodes connected exclusively via Tailscale WireGuard; no direct internet management exposure; ACL enforced per device/subnet.                                                   | Compliant — strengthened |
| <b>Control 13</b> | <b>13.1</b> | Cloud security event alerting: AWS GuardDuty findings → CloudWatch Events; GCP SCC findings → alerting policies; Azure Sentinel KQL rules → automated incident creation; all feed on-premises SIEM via Wazuh.     | Compliant — strengthened |
| <b>Control 13</b> | <b>13.2</b> | Cloud host-based IDS: Wazuh EDR deployed on all 8 cloud nodes (FIM, rootkit detection, process monitoring, CIS SCA); cloud findings visible in on-premises Wazuh dashboard.                                       | Compliant — strengthened |
| <b>Control 13</b> | <b>13.5</b> | Cloud remote asset access control: Tailscale ACL policy enforces per-device/per-subnet explicit allow rules; Wazuh agent compliance verification extended to cloud nodes; no implicit trust.                      | Compliant — strengthened |
| <b>Control 13</b> | <b>13.6</b> | Cloud traffic flow logs: AWS VPC flow logs (CloudWatch Logs), GCP VPC flow logs (Flow Analyzer), Azure NSG flow logs (Network Watcher), Tailscale tunnel telemetry; all supplement on-premises pfSense flow data. | Compliant — strengthened |
| <b>Control 15</b> | <b>15.1</b> | Service provider inventory expanded: AWS (us-east-2), Azure (North Central US), GCP (us-central1) added; cloud provider security posture tools (GuardDuty, SCC, Defender for Cloud) documented.                   | Compliant — strengthened |

## CIS Control 1: Inventory and Control of Enterprise Assets

| Safeguard | Requirement                                                | Implementation                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Notes                                                                                |
|-----------|------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| 1.1       | Establish and maintain detailed enterprise asset inventory | External Excel Inventory, Checkmk inventory, Wazuh agent inventory (25+ endpoints), Prometheus node exporters, PatchMon tracking (30+ hosts), DNS records, SSH host keys in Ansible. Cloud inventory: 8 cloud nodes across AWS (EC2 t3.micro Amazon Linux 2, c7i-flex.large Windows Server 2025), GCP (2x e2.micro, us-central1-c), and Azure (Standard_B2ats_v2 Ubuntu 24.04, Standard_E2s_v3 Windows Server 2025) — all enrolled in Checkmk, Wazuh, and PatchMon via Tailscale. | Compliant — Multiple sources provide comprehensive coverage including cloud nodes    |
| 1.2       | Address unauthorized assets weekly                         | Partial — NetaalertX network discovery identifies unknown on-premises devices. Cloud asset weekly review documented: Tailscale admin console (tailf07c05.ts.net) lists all enrolled nodes; AWS EC2, GCP Compute, and Azure VM consoles serve as authoritative cloud inventory sources reviewed weekly alongside NetaalertX.                                                                                                                                                       | N/A — Single user lab environment                                                    |
| 1.3       | Utilize an active discovery tool (IG2)                     | On-premises: NetaalertX network discovery, nmap scans, custom Python scanner. Cloud: AWS VPC flow logs and GCP VPC flow logs supplement active discovery; cloud-provider instance APIs queried for authoritative node inventory; all cloud nodes enrolled in Tailscale admin console.                                                                                                                                                                                             | Compliant — Active scanning implemented on-premises; cloud-native discovery in place |
| 1.4       | Use DHCP logging to update inventory (IG2)                 | Asus Router DHCP logs (192.168.1.0/24) + pfSense DHCP logs (192.168.100.0/24) forwarded to Splunk/Elastic. Cloud nodes use private IPs assigned via provider DHCP (AWS 172.31.x, GCP 10.128.x, Azure 10.130.x) — IP assignments logged in provider VPC/VNet DHCP lease records.                                                                                                                                                                                                   | Compliant — DHCP logging centralized; cloud static assignments documented            |
| 1.5       | Use passive asset discovery tool (IG3)                     | NetAlertX provides real-time alerts for new MAC/IP associations on-premises, while Suricata performs deep packet inspection to identify asset types. Cloud segments are monitored via Flow Logs, ensuring that even 'silent' or non-scannable assets are captured in the master inventory                                                                                                                                                                                         | Compliant — Passive discovery via traffic analysis extended to cloud segments        |

**Control 1 Overall Status: Compliant — Cloud node inventory integrated; minor process documentation gap in combined review procedure**

## CIS Control 2: Inventory and Control of Software Assets

| Safeguard | Requirement                                       | Implementation                                                                                                                                                                                                                                                                                                                                                                       | Notes                                                                                           |
|-----------|---------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| 2.1       | Establish and maintain software inventory         | External Excel Inventory, PatchMon Software Inventory (5,000+ packages across 30+ on-premises hosts + 4 Linux cloud nodes), Checkmk inventory, Nessus software scanning, Wazuh agent software tracking. Cloud: PatchMon extended to Amazon Linux 2, Debian 13.4, and Ubuntu 24.04 LTS cloud nodes with daily NVD CVE correlation. Windows cloud nodes (AWS, Azure) tracked via WSUS. | Compliant — Multi-source software inventory including cloud nodes                               |
| 2.2       | Ensure authorized software is currently supported | PatchMon tracks EOL software; vulnerability scanners flag unsupported versions; documented exceptions for necessary legacy software. Cloud: AWS Amazon Linux 2 EOL status monitored; Azure/GCP OS image currency tracked via Checkmk and Wazuh vulnerability assessment; WSUS validates Windows Server 2025 support currency.                                                        | Compliant — Supported software validation extended to cloud workloads                           |
| 2.3       | Address unauthorized software monthly             | N/A — Single-user lab environment                                                                                                                                                                                                                                                                                                                                                    | N/A                                                                                             |
| 2.4       | Utilize automated software inventory tools (IG2)  | PatchMon agent-based inventory, Checkmk, Wazuh software tracking, Nessus authenticated scans. Cloud: PatchMon agents deployed on all 6 Linux cloud nodes; Wazuh agents on all 8 cloud nodes provide real-time package and process inventory; automated daily checks.                                                                                                                 | Compliant — Automated discovery extended to cloud nodes                                         |
| 2.5       | Allowlist authorized software (IG2)               | Not Implemented — No application allowlisting solution deployed on-premises or cloud nodes.                                                                                                                                                                                                                                                                                          | Gap — Implement AppLocker/WDAC (Windows), AWS Systems Manager (cloud), or CrowdSec allowlisting |
| 2.6       | Allowlist authorized libraries (IG2)              | Not Implemented — No DLL/library allowlisting on-premises or cloud nodes.                                                                                                                                                                                                                                                                                                            | Gap — IG2 requirement not addressed                                                             |
| 2.7       | Allowlist authorized scripts (IG3)                | Not Implemented — No script execution control (PowerShell Constrained                                                                                                                                                                                                                                                                                                                | Gap — IG3 requirement not addressed                                                             |



Language Mode, etc.) on-premises or cloud nodes.

**Control 2 Overall Status: Partially Compliant — IG1 fully compliant including cloud scope; IG2/IG3 gaps in allowlisting remain**

### CIS Control 3: Data Protection

| Safeguard | Requirement                                      | Implementation                                                                                                                                                                                                                                                                                                                                                                              | Notes     |
|-----------|--------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 3.1       | Establish and maintain a data management process | Documented in GRC document; data classification, retention, disposal procedures defined. Cloud scope added: AWS S3 CloudTrail log buckets (SSE, 90-day retention), GCP Cloud Storage (default encryption, audit logging), Azure Log Analytics workspace homelab-log (90-day retention, encrypted at rest).                                                                                  | Compliant |
| 3.2       | Establish and maintain data inventory            | Sensitive data tracked in inventory; backup data cataloged; scan credentials documented. Cloud data inventory: AWS S3 buckets, GCP GCS buckets, Azure Log Analytics workspace, and cloud node EBS/Managed Disk/persistent disk volumes documented with owner, sensitivity classification, and retention policy.                                                                             | Compliant |
| 3.3       | Configure data access control lists              | File system ACLs; SSH key-based access; database access controls; Authentik RBAC. Cloud: AWS IAM instance profiles with least-privilege roles (no wildcard actions, no long-lived access keys on EC2); GCP service accounts with minimal role assignments (no owner/editor on Compute instances); Azure RBAC scoped per resource group; Tailscale ACL policy governs all inter-node access. | Compliant |
| 3.4       | Enforce data retention                           | 90-day log retention; backup retention policies; automated cleanup. Cloud: AWS CloudTrail logs delivered to S3 with 90-day lifecycle policy; GCP Admin Activity logs retained per GCP defaults; Azure Log Analytics homelab-log configured for 90-day retention matching on-premises SIEM policy.                                                                                           | Compliant |
| 3.5       | Securely dispose of data                         | Secure deletion procedures; encrypted backup disposal; NIST SP 800-88 alignment. Cloud: AWS EC2 EBS volume deletion documented in decommissioning runbook; GCP persistent disk deletion policy                                                                                                                                                                                              | Compliant |

|             |                                            |                                                                                                                                                                                                                                                                                                                                                 |                                                                                              |
|-------------|--------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
|             |                                            | documented; Azure Managed Disk cleanup included in decommissioning checklist.                                                                                                                                                                                                                                                                   |                                                                                              |
| <b>3.6</b>  | Encrypt data on end-user devices           | Windows BitLocker, Linux LUKS, encrypted laptop drives. Cloud nodes not classified as end-user devices; cloud storage encryption covered under 3.11.                                                                                                                                                                                            | Compliant                                                                                    |
| <b>3.7</b>  | Establish data classification scheme (IG2) | Sensitivity tiers (Public, Internal, Confidential, Restricted) defined with handling requirements; used in documentation. Cloud data classified under same scheme: CloudTrail logs (Confidential), GCP audit logs (Confidential), Wazuh agent telemetry (Internal).                                                                             | Compliant                                                                                    |
| <b>3.8</b>  | Document data flows (IG2)                  | Partial — Network architecture documented; full data flow diagrams not comprehensive on-premises. Cloud data flows added: Wazuh agent telemetry (cloud nodes → Tailscale → Wazuh Manager 192.168.1.219), CloudTrail (AWS API → S3), GCP Audit Logs (GCP API → Cloud Logging), Azure Monitor (Azure API → Log Analytics homelab-log → Sentinel). | Gap — Cloud flow paths documented; comprehensive on-premises data flow diagrams still needed |
| <b>3.9</b>  | Encrypt data on removable media (IG2)      | USB drives encrypted; backup tapes encrypted. Cloud nodes have no removable media; cloud storage encryption covered under 3.11.                                                                                                                                                                                                                 | Compliant                                                                                    |
| <b>3.10</b> | Encrypt sensitive data in transit (IG2)    | TLS 1.3 (Traefik), SSH encryption, syslog-ng TLS, VPN encryption. Cloud: all management traffic encrypted via Tailscale WireGuard (ChaCha20-Poly1305); SSH AES-256-GCM for Linux cloud node terminal access; cloud VPC/VNet internal traffic uses provider-encrypted private networking; no plaintext management paths exist.                   | Compliant                                                                                    |
| <b>3.11</b> | Encrypt sensitive data at rest (IG2)       | Encrypted backups, database encryption, scan credential encryption. Cloud: AWS S3 server-side encryption (SSE-S3) for CloudTrail logs; GCP persistent disks encrypted by default (Google-managed keys); Azure Managed Disks encrypted at rest by default; Azure Log Analytics workspace data encrypted at rest.                                 | Compliant                                                                                    |

|             |                                                    |                                                                                                                                                                                                                                                                                                                                                          |                                                                                         |
|-------------|----------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| <b>3.12</b> | Segment data processing based on sensitivity (IG2) | VLAN segmentation; backend isolation (Traefik); network segmentation. Cloud: per-provider network isolation — AWS VPC (172.31.0.0/16), GCP VPC (10.128.0.0/16), Azure VNet homelab-vnet2 (10.130.0.0/16) each isolated from other providers; inter-cloud communication only via Tailscale overlay.                                                       | Compliant                                                                               |
| <b>3.13</b> | Deploy Data Loss Prevention solution (IG3)         | Not Implemented — No DLP solution deployed on-premises or for cloud egress paths. Cloud egress filtering: AWS Security Group outbound rules restrict to required management destinations; GCP VPC firewall policy limits egress to documented management services; Azure NSG outbound rules enforce explicit allow-list. Formal DLP planned Q2 2026.     | Gap — IG3 requirement; provider egress filtering provides partial compensating control  |
| <b>3.14</b> | Log sensitive data access (IG3)                    | Partial — File access logged via Wazuh FIM; database query logging not comprehensive. Cloud: AWS CloudTrail logs all S3 data access (GetObject/PutObject); GCP Data Access audit logs capture GCS bucket access; Azure Log Analytics access logged via Azure Monitor; Wazuh FIM on all 8 cloud nodes monitors file access in configured sensitive paths. | Gap — On-premises database audit logging incomplete; cloud data access logging improved |

**Control 3 Overall Status: IG1/IG2 Compliant including cloud scope; IG3 Partial (DLP not deployed, cloud egress filtering provides compensating control)**

## CIS Control 4: Secure Configuration of Enterprise Assets and Software

| Safeguard  | Requirement                                         | Implementation                                                                                                                                                                                                                                                                                                                                                                                                         | Notes                                                                                                   |
|------------|-----------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------|
| <b>4.1</b> | Establish and maintain secure configuration process | CIS Benchmark audits via Wazuh SCA; configuration drift detection; automated remediation via Ansible; Ansible baselines; IaC version control. Cloud: Ansible linux_hardening.yml and new_install_baseline_roles.yml applied to all 6 Linux cloud nodes via SSH over Tailscale; Azure ARM template (azuredeploy.json) version-controlled in Git; cloud configurations stored in same Git repository as on-premises IaC. | Action Required — Formal secure configuration policy document needed; cloud scope added to existing IaC |
| <b>4.2</b> | Establish secure configuration process for          | Network device hardening standards documented; SSH hardening policy; firewall rule standards. Cloud: AWS Security Group rules documented                                                                                                                                                                                                                                                                               | Compliant                                                                                               |

|            |                                        |                                                                                                                                                                                                                                                                                                                                                                                        |           |
|------------|----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
|            | network infrastructure                 | (tailscale-access + lab-services with explicit inbound/outbound allow-list); GCP VPC network firewall policy (homelab, 17 rules, Google Threat Intelligence blocking for TOR exit nodes, malicious IPs, and sanctioned countries); Azure NSG homelab-nsg2 (explicit allow-list, DenyAllInBound at priority 65500).                                                                     |           |
| <b>4.3</b> | Configure automatic session locking    | 15-min timeout (general OS); 2-min timeout (mobile devices); enforced via GPO/Ansible. Cloud Windows nodes (AWS, Azure) subject to same GPO session lock policy via domain join to home.com over Tailscale.                                                                                                                                                                            | Compliant |
| <b>4.4</b> | Implement firewall on servers          | UFW (Linux), Windows Firewall, iptables rules managed via Ansible. Cloud: AWS Security Groups serve as host-level firewall for EC2 instances; GCP VPC network firewall policy applies to all Compute instances; Azure NSG homelab-nsg2 applied at subnet level to all Azure VMs; Ansible linux_hardening.yml configures UFW on Linux cloud nodes as an additional host-based layer.    | Compliant |
| <b>4.5</b> | Implement firewall on end-user devices | Host-based firewalls enabled on all endpoints; default-deny ruleset. Cloud nodes are servers, not end-user devices; host-based firewalls covered under 4.4.                                                                                                                                                                                                                            | Compliant |
| <b>4.6</b> | Securely manage enterprise assets      | SSH key-based admin access; IaC version control (Git); HTTPS-only management interfaces. Cloud: all SSH/RDP to cloud nodes restricted to homelab subnets (192.168.0.0/16) via provider-native firewall rules; Tailscale WireGuard mandatory for all cloud management access; no public management ports exposed on any cloud instance; cloud console access via provider IAM with MFA. | Compliant |
| <b>4.7</b> | Manage default accounts                | Root login disabled (SSH); default vendor accounts removed; validated via Nessus scans. Cloud: Ansible new_install_baseline_roles.yml disables root SSH login and removes default accounts on Linux cloud nodes; Windows cloud nodes joined to domain and local Administrator account managed via GPO.                                                                                 | Compliant |

|             |                                                        |                                                                                                                                                                                                                                                                                                                                |                                                                                                 |
|-------------|--------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>4.8</b>  | Uninstall unnecessary services (IG2)                   | Minimal service footprint; unnecessary services disabled; verified via authenticated scans. Cloud: cloud nodes provisioned with minimal base images (Amazon Linux 2 minimal, Debian/Ubuntu server); Wazuh SCA validates running services against CIS benchmarks on all cloud nodes.                                            | Compliant                                                                                       |
| <b>4.9</b>  | Configure trusted DNS servers (IG2)                    | Enterprise-controlled DNS (Technitium DNS/Unbound); DNSSEC validation. Cloud: all Linux cloud nodes configured with on-premises Unbound resolvers (192.168.1.153, 192.168.1.154) as DNS servers via Tailscale tunnel; Windows cloud nodes (domain-joined) use on-premises AD DNS (192.168.1.152, 192.168.1.142) via Tailscale. | Compliant                                                                                       |
| <b>4.10</b> | Enforce automatic lockout on portable devices (IG2)    | Failed auth lockout (laptops: 20 attempts; mobile: 10 attempts) via GPO/MDM. Cloud Windows nodes subject to same account lockout GPO (5 failed attempts, 10-minute lockout) applied via domain policy over Tailscale.                                                                                                          | Compliant                                                                                       |
| <b>4.11</b> | Enforce remote wipe capability (IG2)                   | Not Implemented — Mobile device wipe capability via planned MDM; laptops rely on full-disk encryption. Cloud: cloud nodes can be terminated/deleted via provider console or API (not a traditional remote wipe but achieves equivalent data destruction). Not a gap for cloud workloads.                                       | Gap — Mobile/laptop remote wipe; cloud instance termination provides equivalent for cloud nodes |
| <b>4.12</b> | Separate enterprise workspaces on mobile devices (IG3) | Not Implemented — No Android Work Profile/iOS Managed App separation.                                                                                                                                                                                                                                                          | Gap — IG3 mobile device management; not applicable to cloud nodes                               |

**Control 4 Overall Status: Needs Process Documentation (4.1 critical); cloud node configuration management integrated into existing IaC**

## CIS Control 5: Account Management

| Safeguard  | Requirement                              | Implementation                                                                                                                                                                                                                                                                       | Notes     |
|------------|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>5.1</b> | Establish and maintain account inventory | Authentik user database, Active Directory accounts, SSH key inventory (Ansible), Wazuh user tracking. Cloud: AWS IAM users/roles and service accounts inventoried in AWS IAM console; GCP service accounts listed in GCP IAM; Azure Entra ID accounts (cloud-only and domain-synced) | Compliant |



|            |                                                 |                                                                                                                                                                                                                                                                                                                           |                                         |
|------------|-------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------|
|            |                                                 | tracked in Azure Active Directory; Wazuh agents on all cloud nodes report active local accounts.                                                                                                                                                                                                                          |                                         |
| <b>5.2</b> | Use unique passwords                            | Vaultwarden password manager; 8-char minimum (MFA accounts); 14-char minimum (non-MFA). Cloud: no shared credentials on cloud nodes; SSH key-based auth for Linux (no passwords); Windows cloud nodes use domain accounts managed by GPO password policy.                                                                 | Compliant — Exceeds CIS recommendations |
| <b>5.3</b> | Disable dormant accounts after 45 days          | Automated via Active Directory account expiration policies; Authentik account lifecycle management. Cloud: AWS IAM access keys reviewed quarterly (no long-lived keys on EC2 — instance profiles used); GCP service accounts audited via IAM recommender; Azure Entra ID accounts subject to same 45-day dormancy policy. | Compliant                               |
| <b>5.4</b> | Restrict admin privileges to dedicated accounts | Separate admin accounts (no dual-use); SSH sudo enforcement; Authentik RBAC. Cloud: AWS IAM instance profiles scoped to minimum required actions (no AdministratorAccess policy); GCP service accounts use minimal roles (no owner/editor); Azure subscription admin access MFA-enforced via Entra Conditional Access.    | Compliant                               |
| <b>5.5</b> | Establish service account inventory (IG2)       | Service accounts documented in inventory; ownership tracked; quarterly reviews. Cloud: AWS IAM instance profiles (terraform-token, ansible) documented; GCP compute service accounts listed; Azure Managed Identity or service principals documented with assigned roles.                                                 | Compliant                               |
| <b>5.6</b> | Centralize account management (IG2)             | Authentik SSO + Active Directory; centralized SSH key management (Ansible). Cloud: Linux cloud nodes use SSH keys distributed via Ansible (same centralized key management as on-premises); Windows cloud nodes domain-joined to home.com via Tailscale, managed by AD.                                                   | Compliant                               |

**Control 5 Overall Status: Fully Compliant — Cloud node accounts integrated into existing lifecycle management**

## CIS Control 6: Access Control Management

| Safeguard | Requirement                                     | Implementation                                                                                                                                                                                                                                                                                                                                                                | Notes     |
|-----------|-------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 6.1       | Establish access granting process               | Documented onboarding procedures; Authentik provisioning; SSH key distribution workflow. Cloud: cloud node access provisioned via Ansible playbook (SSH key deployment for Linux, domain join for Windows); AWS IAM role assignment documented; GCP service account grant process documented.                                                                                 | Compliant |
| 6.2       | Establish access revocation process             | Offboarding checklist; Authentik account deactivation; SSH key revocation (Ansible); Wazuh Active Response. Cloud: cloud node access revocation: SSH key removal via Ansible, Tailscale node key expiry/revocation, AWS IAM instance profile disassociation; cloud node termination as final revocation step.                                                                 | Compliant |
| 6.3       | Require MFA for externally-exposed applications | Authentik enforces MFA via TOTP; all external services require MFA. Cloud: AWS console access enforces MFA via IAM policy; GCP console access requires Google account MFA; Azure portal access enforces MFA via Entra Conditional Access policy. Cloud node management interfaces (SSH/RDP) require Tailscale device authentication (device-bound key, no shared credential). | Compliant |
| 6.4       | Require MFA for remote network access           | VPN (Tailscale) requires device authentication; SSH keys + optional passphrase. Cloud: all cloud node management access routes through Tailscale WireGuard; Tailscale device authentication requires MFA at enrollment; no direct internet-facing management ports on any cloud node.                                                                                         | Compliant |
| 6.5       | Require MFA for administrative access           | 100% admin accounts require Authentik MFA; SSH key-based                                                                                                                                                                                                                                                                                                                      | Compliant |

|     |                                                               |                                                                                                                                                                                                                                                                                                                                                  |                                                                                          |
|-----|---------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|
|     |                                                               | auth for privileged access. Cloud: AWS IAM admin users require MFA (enforced via IAM policy); GCP admin access requires Google MFA; Azure subscription administrators enforce MFA via Entra Conditional Access; cloud node admin SSH access via Tailscale (device-bound key).                                                                    |                                                                                          |
| 6.6 | Establish authentication/authorization system inventory (IG2) | Authentik, Active Directory, SSH key infrastructure documented; annual review. Cloud: AWS IAM (authentication/authorization for AWS APIs and console), GCP IAM (GCP resources), Azure Entra ID (Azure resources and domain-joined cloud nodes) added to auth system inventory.                                                                   | Compliant                                                                                |
| 6.7 | Centralize access control (IG2)                               | Authentik SSO for Traefik-routed services; Active Directory domain authentication. Cloud: Linux cloud nodes centralized via Ansible-managed SSH keys; Windows cloud nodes centralized via Active Directory (domain-joined over Tailscale); cloud console access centralized via provider IAM with MFA.                                           | Compliant                                                                                |
| 6.8 | Define and maintain role-based access control (IG3)           | Not Implemented — Requires enterprise-wide RBAC documentation (access rights per role for all systems). Cloud: AWS IAM instance profiles define EC2 role boundaries; GCP IAM service account roles defined; Azure RBAC role assignments documented per resource group. Formal RBAC matrix across all systems including cloud not yet documented. | Action Required — RBAC documentation needed; cloud IAM role boundaries partially defined |

**Control 6 Overall Status: Mostly Compliant; 6.8 needs broader RBAC documentation including cloud IAM roles**

## CIS Control 7: Continuous Vulnerability Management

| Safeguard | Requirement                                | Implementation                                                                                                                                    | Notes     |
|-----------|--------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 7.1       | Establish vulnerability management process | Documented dual-scanner approach (OpenVAS + Nessus); remediation SLAs; CVSS prioritization. Cloud: same CVSS-based SLAs (Critical <72h, High <7d) | Compliant |

|            |                                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |                                                                    |
|------------|--------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|
|            |                                                        | applied to cloud node findings from PatchMon, AWS Inspector, GCP SCC, and Azure Defender for Cloud; TheHive tracks cloud node vulnerabilities alongside on-premises findings.                                                                                                                                                                                                                                                                                                 |                                                                    |
| <b>7.2</b> | Establish remediation process                          | Risk-based remediation strategy; documented SLAs; monthly reviews; TheHive tracking. Cloud: Ansible update_linux_hosts.yml provides emergency patching for Linux cloud nodes via Tailscale; WSUS manages Windows cloud nodes; cloud-native remediation (AWS Systems Manager Patch Manager, GCP OS Patch Management, Azure Update Manager) available as supplemental tools.                                                                                                    | Compliant                                                          |
| <b>7.3</b> | Perform automated OS patch management                  | PatchMon (Linux), WSUS (Windows), monthly cadence; automated approvals. Cloud: WSUS manages Windows cloud nodes (AWS Windows Server 2025, Azure Windows Server 2025) with same approval workflow and schedule as on-premises Windows hosts. Ansible update_linux_hosts.yml patches Linux cloud nodes (Amazon Linux 2, Debian 13.4, Ubuntu 24.04 LTS) monthly via Tailscale; n8n workflow triggers cloud patching alongside on-premises patching runs.                         | Compliant —<br>Extended to cloud nodes                             |
| <b>7.4</b> | Perform automated application patch management         | Watchtower (containers), WUD monitoring, monthly cadence. Cloud: Watchtower and WUD monitor container images on cloud nodes where Docker is deployed; cloud node base OS patching covers cloud-hosted application dependencies.                                                                                                                                                                                                                                               | Compliant                                                          |
| <b>7.5</b> | Perform automated vulnerability scans — internal (IG2) | Weekly OpenVAS (52/year); monthly Nessus authenticated scans (12/year). Cloud: Wazuh agents run CIS SCA on all 8 cloud nodes daily (CIS Amazon Linux, Debian 12/13, Ubuntu 22.04/24.04, Windows Server 2025); AWS Inspector provides agent-based vulnerability assessment for EC2 nodes; GCP SCC vulnerability assessment for Compute instances; Azure Defender for Cloud recommendations for Azure VMs. All cloud findings visible in unified PatchMon and Wazuh dashboards. | Compliant —<br>Exceeds quarterly requirement; cloud scanning added |

|            |                                                        |                                                                                                                                                                                                                                                                                                                                                                         |                                                |
|------------|--------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------|
| <b>7.6</b> | Perform automated vulnerability scans — external (IG2) | Monthly Nessus scans of externally-exposed assets; OpenVAS external scans. Cloud: AWS Inspector external-facing assessment for internet-attached EC2 resources; GCP SCC external threat detection for Compute nodes; Azure Defender for Cloud internet-exposed resource assessment. Note: no cloud management ports are publicly exposed — attack surface is minimal.   | Compliant                                      |
| <b>7.7</b> | Remediate detected vulnerabilities (IG2)               | MTTR <72h (Critical); <7 days (High); 95% patched within SLA; verification scans. Cloud: same MTTR SLAs enforced across cloud nodes via PatchMon tracking; Ansible emergency patching available for Linux cloud nodes via Tailscale; WSUS auto-approval for critical Windows cloud node patches; cloud findings verified via follow-up Wazuh SCA scan post-remediation. | Compliant — SLAs maintained across cloud scope |

**Control 7 Overall Status: Fully Compliant — Exceeds industry standards; cloud node vulnerability management integrated**

## CIS Control 8: Audit Log Management

| Safeguard  | Requirement                            | Implementation                                                                                                                                                                                                                                                                                                                                                                                                                                     | Notes     |
|------------|----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>8.1</b> | Establish audit log management process | Documented logging policy; 90-day retention; centralized SIEM; review procedures. Cloud scope added: cloud-native audit logs (AWS CloudTrail, GCP Admin Activity, Azure Activity Log) included in logging policy with 90-day retention requirement matched across all providers.                                                                                                                                                                   | Compliant |
| <b>8.2</b> | Collect audit logs                     | 100% security event coverage (DNS, SSH, Traefik, vulnerability scans, patches, Wazuh, Sysmon). Cloud: AWS CloudTrail collects all management events (delivered to S3 with SSE); GCP Admin Activity logs always-on (cannot be disabled), Data Access audit logs enabled; Azure Activity Log and Monitor collect all ARM deployments and resource changes; Wazuh agent on all 8 cloud nodes forwards endpoint security events to on-premises Splunk. | Compliant |
| <b>8.3</b> | Ensure adequate log storage            | SIEM storage capacity planning; immutable indexes; compressed archival. Cloud: AWS S3 lifecycle policies manage CloudTrail log retention; GCP                                                                                                                                                                                                                                                                                                      | Compliant |

|            |                                        |                                                                                                                                                                                                                                                                                                                                                                     |           |
|------------|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
|            |                                        | Cloud Logging retention configured; Azure Log Analytics homelab-log workspace storage monitored; cloud-native log storage supplementary to on-premises SIEM.                                                                                                                                                                                                        |           |
| <b>8.4</b> | Standardize time synchronization (IG2) | NTP sync across all assets; centralized time sources. Cloud: all Linux cloud nodes configured with NTP (time.google.com, time.cloudflare.com) via Ansible; Windows cloud nodes sync via domain NTP policy; cloud provider hypervisors provide host-level time sync as a baseline.                                                                                   | Compliant |
| <b>8.5</b> | Collect detailed audit logs (IG2)      | Logs include timestamp, user, source IP, action, result, SSH key fingerprints, DNS query details. Cloud: AWS CloudTrail includes IAM identity, source IP, user agent, request/response detail; GCP audit logs include principal identity, resource, method, source IP; Azure Activity Log includes caller identity, resource, operation, source IP.                 | Compliant |
| <b>8.6</b> | Collect DNS query logs (IG2)           | Unbound/Technitium DNS query logging; forwarded to SIEM. Cloud: all cloud nodes resolve via on-premises Unbound resolvers (192.168.1.153/154) over Tailscale — DNS queries logged at Unbound and forwarded to SIEM; AWS Route 53 Resolver DNS query logging enabled for VPC; GCP Cloud DNS logging for internal queries.                                            | Compliant |
| <b>8.7</b> | Collect URL request logs (IG2)         | Traefik access logs (JSON format); proxy logs; forwarded to SIEM. Cloud: cloud-hosted services (where applicable) log via Traefik or cloud-native application logging; GCP Cloud Armor access logs capture HTTP request details; Azure Application Gateway access logs (where applicable).                                                                          | Compliant |
| <b>8.8</b> | Collect command-line logs (IG2)        | Sysmon Event ID 1 (process creation); PowerShell logging; Bash history; Wazuh command monitoring. Cloud: Wazuh agents on all 8 cloud nodes collect process execution, command-line arguments, and shell history; Windows cloud nodes have Sysmon deployed with same configuration as on-premises Windows hosts; Bash audit logging via auditd on Linux cloud nodes. | Compliant |



|             |                                         |                                                                                                                                                                                                                                                                                                                                                                                                                      |                                                                                     |
|-------------|-----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
| <b>8.9</b>  | Centralize audit logs (IG2)             | Dual SIEM (Splunk + Elastic); syslog-ng encrypted forwarding; centralized storage. Cloud: Wazuh Universal Forwarder from all 8 cloud nodes forwards to on-premises Splunk via Tailscale; AWS CloudTrail logs stored in S3 (provider-managed); GCP audit logs in Cloud Logging (provider-managed); Azure logs in homelab-log Log Analytics workspace; all cloud node endpoint events centralized in on-premises SIEM. | Compliant                                                                           |
| <b>8.10</b> | Retain audit logs 90 days minimum (IG2) | 90-day retention policy; immutable SIEM indexes. Cloud: AWS S3 CloudTrail bucket lifecycle policy set to 90 days; GCP Cloud Logging default retention (400 days for admin activity); Azure Log Analytics homelab-log retention set to 90 days; cloud endpoint events forwarded to on-premises SIEM subject to 90-day hot / 1-year cold retention.                                                                    | Compliant                                                                           |
| <b>8.11</b> | Conduct audit log reviews weekly (IG2)  | Splunk dashboards; Wazuh alerts; weekly correlation searches; automated reviews. Cloud: AWS GuardDuty findings reviewed as generated (real-time); GCP SCC security health findings reviewed monthly; Azure Sentinel dashboard includes cloud node events; Wazuh dashboards show cloud node alert trends alongside on-premises.                                                                                       | Compliant                                                                           |
| <b>8.12</b> | Collect service provider logs (IG3)     | Partial — Cloud service logs collected where available; not comprehensive across all SaaS platforms. Cloud: AWS CloudTrail, GCP Admin Activity, and Azure Activity logs collected and available for correlation; coverage improved significantly with cloud IaaS integration. SaaS platform log collection (non-IaaS) remains limited.                                                                               | IG3 Partial — IaaS cloud audit logging comprehensive; SaaS platform logging limited |

**Control 8 Overall Status: Fully Compliant (IG1/IG2) — Cloud audit logs integrated; IG3 improved with IaaS log coverage**

## CIS Control 9: Email and Web Browser Protections

| Safeguard  | Requirement                                        | Implementation                                                                                                                                                                       | Notes     |
|------------|----------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>9.1</b> | Ensure only fully supported browsers/email clients | Latest browser versions enforced; unsupported clients blocked; automated update verification. Cloud: cloud nodes are servers; no browser/email client deployment on cloud instances. | Compliant |

|            |                                          |                                                                                                                                                                                                                                                                                                             |                                                      |
|------------|------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------|
| <b>9.2</b> | Use DNS filtering services               | Unbound integrated blocklists (1M+ blocked domains); malware/phishing domain blocking. Cloud: all cloud nodes resolve via on-premises Unbound (192.168.1.153/154) over Tailscale, inheriting DNS-layer malware and phishing domain blocking.                                                                | Compliant                                            |
| <b>9.3</b> | Maintain network-based URL filters (IG2) | Traefik URL filtering; SafeLine WAF; category-based blocking; reputation filtering. Cloud: GCP Cloud Armor application-level policy blocks malicious URL patterns; AWS Security Group egress rules restrict outbound destinations; Azure NSG outbound rules limit egress to documented management services. | Compliant                                            |
| <b>9.4</b> | Restrict browser/email extensions (IG2)  | GPO restricts extensions on managed Windows devices; Linux/personal devices rely on user compliance. Cloud: cloud nodes are servers; no browser extension management applicable.                                                                                                                            | Gap — Applies to endpoints; cloud nodes not affected |
| <b>9.5</b> | Implement DMARC (IG2)                    | DMARC policy published; SPF + DKIM implemented for outbound mail. Cloud: no change; email infrastructure unchanged.                                                                                                                                                                                         | Compliant                                            |
| <b>9.6</b> | Block unnecessary file types (IG2)       | Email gateway blocks .exe/.scr/.bat attachments; not comprehensive. Cloud: no change; cloud nodes are servers with no email client.                                                                                                                                                                         | Gap — Expand blocked file type list on email gateway |
| <b>9.7</b> | Deploy email server anti-malware (IG3)   | Not Implemented — No dedicated email gateway anti-malware (homelab uses external email providers).                                                                                                                                                                                                          | Gap — IG3 N/A (no on-prem email server)              |

**Control 9 Overall Status: IG1 Compliant; IG2 Partial; IG3 N/A (no on-prem email server).**  
**Cloud DNS filtering extended to all cloud nodes.**

## CIS Control 10: Malware Defenses

| Safeguard   | Requirement                               | Implementation                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Notes     |
|-------------|-------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>10.1</b> | Deploy and maintain anti-malware software | Wazuh FIM + VirusTotal integration; ClamAV; Microsoft Defender; rootkit detection. Cloud: Wazuh FIM and rootkit detection deployed on all 8 cloud nodes (same monitored path configuration as on-premises); ClamAV on Linux cloud nodes (Amazon Linux 2, Debian 13.4, Ubuntu 24.04 LTS); Microsoft Defender active on Windows Server 2025 (AWS, Azure); GuardDuty (AWS), SCC (GCP), and Azure Defender for Cloud provide cloud-native behavioral detection layer. | Compliant |

|      |                                                       |                                                                                                                                                                                                                                                                                                                                                                 |           |
|------|-------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 10.2 | Configure automatic anti-malware signature updates    | Automated signature updates (daily); ClamAV freshclam; Defender definition updates. Cloud: ClamAV freshclam runs on Linux cloud nodes; Windows Defender definitions updated via WSUS on Windows cloud nodes; cloud-native tools (GuardDuty, SCC, Defender for Cloud) update threat intelligence automatically with no manual intervention.                      | Compliant |
| 10.3 | Disable autorun/autoplay for removable media          | GPO disables autorun; Linux udev rules block autoplay; verified compliance. Cloud: cloud nodes have no removable media; not applicable.                                                                                                                                                                                                                         | Compliant |
| 10.4 | Configure automatic scanning of removable media (IG2) | Wazuh FIM monitors USB insertions; ClamAV on-access scanning. Cloud: no removable media on cloud nodes; not applicable.                                                                                                                                                                                                                                         | Compliant |
| 10.5 | Enable anti-exploitation features (IG2)               | Windows DEP/WDEG enabled; Linux ASLR/PIE; macOS SIP/Gatekeeper. Cloud: Linux cloud nodes have ASLR enabled (enforced via Ansible sysctl hardening); Windows cloud nodes (Windows Server 2025) have DEP, ASLR, and Control Flow Guard enabled by default.                                                                                                        | Compliant |
| 10.6 | Centrally manage anti-malware software (IG2)          | Wazuh central management; Group Policy for Windows Defender; centralized config. Cloud: Wazuh manager (192.168.1.219) centrally manages all cloud node agents; Windows cloud nodes managed via Group Policy over Tailscale domain connection.                                                                                                                   | Compliant |
| 10.7 | Use behavior-based anti-malware (IG2)                 | Wazuh behavioral analysis; Windows Defender behavior monitoring; Suricata IDS behavioral detection. Cloud: AWS GuardDuty ML-based behavioral detection (no signature maintenance required); GCP SCC threat detection; Azure Defender for Cloud behavioral analytics — all provide cloud-native behavioral malware detection independent of signature databases. | Compliant |

**Control 10 Overall Status: Fully Compliant — Anti-malware coverage extended to all cloud nodes; cloud-native behavioral detection supplements on-premises**

## CIS Control 11: Data Recovery

| Safeguard | Requirement | Implementation | Notes |
|-----------|-------------|----------------|-------|
|-----------|-------------|----------------|-------|

|      |                                              |                                                                                                                                                                                                                                                                                                                                     |           |
|------|----------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 11.1 | Establish and maintain data recovery process | Documented backup procedures; restore workflows; recovery prioritization; annual reviews. Cloud recovery procedures added: ARM template (Azure), Ansible new_install_baseline_roles.yml, and Tailscale re-enrollment documented as cloud node rebuild runbooks; RTO target <2hr for cloud nodes.                                    | Compliant |
| 11.2 | Perform automated backups                    | Proxmox automated backups (bi-weekly); Docker volume backups; database backups; weekly cadence. Cloud: cloud node OS-level backups via provider snapshots (AWS EBS snapshots, GCP disk snapshots, Azure VM snapshots); application data backed up to on-premises PBS/NAS via Tailscale where applicable.                            | Compliant |
| 11.3 | Protect recovery data                        | Encrypted backups (AES-256); offsite storage; access controls; encrypted transmission. Cloud: AWS EBS snapshots encrypted (account default KMS key); GCP disk snapshots encrypted at rest; Azure VM snapshots encrypted; S3 CloudTrail backup bucket with SSE; all cloud snapshot access controlled via provider IAM.               | Compliant |
| 11.4 | Establish isolated instance of recovery data | Offsite backups (cloud + offline USB); air-gapped backup copies; versioned backups. Cloud: cloud node rebuild from code (Git + Ansible) provides an infrastructure-as-code recovery path independent of backup images; Tailscale pre-authorized keys stored offline for re-enrollment.                                              | Compliant |
| 11.5 | Test data recovery (IG2)                     | Quarterly restore testing; documented test results; validation procedures. Cloud recovery validated: Azure Spot instance eviction scenario tested (Deallocate policy, restart procedure documented); AWS EC2 stop/start tested; GCP Compute stop/start tested; Ansible cloud node rebuild timing validated against <2hr RTO target. | Compliant |

**Control 11 Overall Status: Fully Compliant — Cloud node recovery procedures documented and tested**

## CIS Control 12: Network Infrastructure Management

| Safeguard | Requirement | Implementation | Notes |
|-----------|-------------|----------------|-------|
|-----------|-------------|----------------|-------|

|             |                                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                              |                                                                                                   |
|-------------|----------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| <b>12.1</b> | Ensure network infrastructure is up-to-date  | Network device patch management; monthly version checks; automated update notifications. Cloud: AWS VPC, GCP VPC, and Azure VNet are provider-managed infrastructure (automatically patched by provider); Tailscale client updated via package manager on all cloud nodes; cloud-native security services updated automatically.                                                                                                                             | Compliant                                                                                         |
| <b>12.2</b> | Establish secure network architecture (IG2)  | Documented network architecture; segmentation design; least-privilege network design. Cloud architecture documented: Tailscale mesh (9 enrolled nodes, tailf07c05.ts.net), per-provider VPC/VNet CIDR allocations (AWS 172.31.0.0/16, GCP 10.128.0.0/16, Azure 10.130.0.0/16), subnet router configurations, and cloud-to-on-premises routing tables. No cloud management ports publicly exposed; default-deny posture on all cloud firewall configurations. | Compliant                                                                                         |
| <b>12.3</b> | Securely manage network infrastructure (IG2) | SSH key-based management; HTTPS-only interfaces; IaC version control (Git). Cloud: cloud network infrastructure (Security Groups, VPC firewall policy, NSG rules) managed via Terraform IaC and version-controlled in Git; no console-based ad-hoc changes; cloud network changes require Git commit and apply workflow.                                                                                                                                     | Compliant                                                                                         |
| <b>12.4</b> | Establish architecture diagrams (IG2)        | Network topology diagrams; Subnet/VLAN documentation; NetAlertX networking mapping. Cloud diagrams added: Tailscale node inventory table (9 nodes with Tailscale IPs and roles), subnet advertisement table (pfSense, AWS, GCP, Azure subnet routers), cloud-to-on-premises routing documentation, per-provider VPC/VNet topology.                                                                                                                           | Compliant                                                                                         |
| <b>12.5</b> | Centralize network AAA (IG2)                 | Not Implemented — Lab does not have a dedicated AAA service deployed for on-premises network devices. Cloud: Tailscale ACL policy serves as de-facto AAA for cloud node access (device-bound authentication, per-node authorization rules, access logging); does not replace traditional 802.1X/RADIUS AAA.                                                                                                                                                  | Gap — Traditional AAA not deployed; Tailscale ACL provides partial compensating control for cloud |

|             |                                              |                                                                                                                                                                                                                                                                                                                                                |                                                  |
|-------------|----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------|
| <b>12.6</b> | Use secure network protocols (IG2)           | 802.1X port security (planned); WPA3 wireless; TLS 1.3; SSH v2 only. Cloud: all cloud management communication via Tailscale WireGuard (modern ChaCha20-Poly1305); SSH v2 AES-256-GCM enforced on all Linux cloud nodes via Ansible; TLS 1.3 for all cloud-hosted HTTPS services.                                                              | Compliant                                        |
| <b>12.7</b> | Ensure remote devices use VPN + AAA (IG2)    | Tailscale mesh VPN requires device authentication; Cloudflare Tunnels; no direct internet exposure. Cloud: all cloud nodes connected exclusively via Tailscale WireGuard; no public management ports; cloud nodes access on-premises management stack (Wazuh, DNS, PatchMon, Checkmk) via Tailscale; device-bound key authentication enforced. | Compliant                                        |
| <b>12.8</b> | Establish dedicated admin workstations (IG3) | Partial — Dedicated admin VM; not fully air-gapped from internet. Cloud management access performed from the same admin workstation via Tailscale; no dedicated cloud-management-only workstation.                                                                                                                                             | Gap — Implement fully isolated admin workstation |

**Control 12 Overall Status: IG1/IG2 Compliant — Cloud network architecture integrated; 12.5 AAA gap remains; IG3 Partial**

### CIS Control 13: Network Monitoring and Defense

| Safeguard   | Requirement                              | Implementation                                                                                                                                                                                                                                                                                                                                                                                              | Notes     |
|-------------|------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>13.1</b> | Centralize security event alerting (IG2) | Dual SIEM (Splunk + Elastic); TheHive case management; Discord/email alerting. Cloud: AWS GuardDuty findings → CloudWatch Events → SNS; GCP SCC findings → alerting policies → notifications; Azure Sentinel KQL detection rules → automated incident creation → Shuffle SOAR webhook → on-premises TheHive case creation. All cloud security events also forwarded to on-premises Splunk via Wazuh agents. | Compliant |
| <b>13.2</b> | Deploy host-based IDS (IG2)              | Wazuh EDR on 25+ endpoints; FIM monitoring; rootkit detection; process monitoring. Cloud: Wazuh EDR deployed on all 8 cloud nodes (same configuration as on-premises) providing FIM, rootkit detection, CIS SCA, vulnerability assessment, and process monitoring. Cloud node findings visible in centralized Wazuh dashboard and Splunk SIEM.                                                              | Compliant |



|             |                                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                            |           |
|-------------|--------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| <b>13.3</b> | Deploy network IDS (IG2)                         | Suricata (IPS inline); Snort (IDS passive); CrowdSec (behavioral). Cloud: AWS GuardDuty analyzes VPC flow logs for network-based threat patterns (port scanning, C2 beaconing, DGA domains); GCP network IDS endpoint configured for gcp-debian-host1 mirroring traffic at high severity threshold; Azure Sentinel NSG flow log analysis detects network anomalies.                                                                                        | Compliant |
| <b>13.4</b> | Perform traffic filtering between segments (IG2) | pfSense/OPNsense inter-VLAN ACLs; firewall rules per segment; default-deny policies. Cloud: AWS Security Groups enforce default-deny between all cloud nodes and the internet; GCP VPC firewall policy (homelab) with Google Threat Intelligence blocking (TOR exit nodes, malicious IPs, sanctioned countries) applies to all GCP Compute instances; Azure NSG homelab-nsg2 applies explicit allow-list with DenyAllInBound and DenyAllOutBound defaults. | Compliant |
| <b>13.5</b> | Manage access control for remote assets (IG2)    | NAC principles applied; Tailscale device posture checks; Wazuh agent compliance verification. Cloud: Tailscale ACL policy enforces per-device/per-subnet explicit allow rules (default deny for all inter-node traffic); Wazuh agent compliance verification extended to all 8 cloud nodes; non-compliant cloud nodes identified via CIS SCA score in Wazuh dashboard.                                                                                     | Compliant |
| <b>13.6</b> | Collect network traffic flow logs (IG2)          | pfSense/OPNsense flow logs; Suricata EVE JSON; packet captures (tcpdump); SIEM ingestion. Cloud: AWS VPC flow logs (fl-03179f74e54bf1aa4 → CloudWatch Logs group) capturing all accepted/rejected traffic with ENI, source/destination, ports, and action; GCP VPC flow logs enabled on default network (Flow Analyzer); Azure NSG flow logs via Network Watcher (homelab-nsg2); Tailscale tunnel telemetry supplements provider flow data.                | Compliant |
| <b>13.7</b> | Deploy host-based IPS (IG3)                      | Wazuh Active Response (firewall-drop, host-deny); EDR blocking capabilities. Cloud: Wazuh Active Response executes on cloud nodes via Tailscale — same containment playbooks as on-premises (firewall-drop via iptables/UFW on Linux,                                                                                                                                                                                                                      | Compliant |

|              |                                               |                                                                                                                                                                                                                                                                                                                                                                               |                                                                                                  |
|--------------|-----------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
|              |                                               | host-deny, account-disable); sub-30-minute MTTR maintained for cloud node containment.                                                                                                                                                                                                                                                                                        |                                                                                                  |
| <b>13.8</b>  | Deploy network IPS (IG3)                      | Suricata inline blocking mode; CrowdSec automated firewall rules; pfSense IPS integration. Cloud: GCP Cloud Armor application-level policy provides WAF blocking (SQLi/XSS via preconfigured expression sets v33-stable) and DDoS rate limiting; AWS Security Group acts as stateful IPS at the VPC perimeter; Azure DDoS Protection plan (homelab-ddos) protects Azure VNet. | Compliant                                                                                        |
| <b>13.9</b>  | Deploy port-level access control (IG3)        | Not Implemented — Network switching replacement required; currently using MAC filtering + admin VLAN segmentation.                                                                                                                                                                                                                                                            | Gap — Implement 802.1X NAC for on-premises; cloud nodes not applicable (no physical switchports) |
| <b>13.10</b> | Perform application layer filtering (IG3)     | Safelane WAF (OWASP CRS rules); Traefik middleware filtering; NGINX Ingress rules. Cloud: GCP Cloud Armor three-tier application-level WAF (edge policy: Tailscale/homelab allow-list; backend policy: DDoS rate limiting; application-level policy: SQLi/XSS blocking); AWS WAF available for ALB-fronted services; Azure Application Gateway WAF available.                 | Compliant                                                                                        |
| <b>13.11</b> | Tune security event alerting thresholds (IG3) | Monthly tuning of Splunk/Wazuh/Suricata thresholds; false positive reduction tracking. Cloud: AWS GuardDuty finding suppression rules configured for known-good activity; GCP SCC security marks used to suppress known-good findings; Azure Sentinel analytics rule tuning via scheduled review.                                                                             | Compliant                                                                                        |

**Control 13 Overall Status: IG2 Fully Compliant; IG3 Mostly Compliant (802.1X gap for on-premises only; cloud nodes well-covered by provider controls)**

## CIS Control 14: Security Awareness and Skills Training

| Safeguard   | Requirement                                      | Implementation                    | Notes |
|-------------|--------------------------------------------------|-----------------------------------|-------|
| <b>14.1</b> | Establish security awareness program             | N/A — Single-user lab environment | N/A   |
| <b>14.2</b> | Train workforce on social engineering            | N/A — Single-user lab environment | N/A   |
| <b>14.3</b> | Train workforce on authentication best practices | N/A — Single-user lab environment | N/A   |

|             |                                                         |                                                                                 |     |
|-------------|---------------------------------------------------------|---------------------------------------------------------------------------------|-----|
| <b>14.4</b> | Train workforce on data handling                        | N/A — Single-user lab environment                                               | N/A |
| <b>14.5</b> | Train workforce on unintentional data exposure          | N/A — Single-user lab environment                                               | N/A |
| <b>14.6</b> | Train workforce on incident recognition/reporting       | N/A — Single-user lab environment                                               | N/A |
| <b>14.7</b> | Train workforce on identifying missing security updates | N/A — Single-user lab environment                                               | N/A |
| <b>14.8</b> | Train workforce on insecure network dangers             | N/A — Single-user lab environment                                               | N/A |
| <b>14.9</b> | Conduct role-specific security training (IG2)           | N/A — Single-user lab environment; hands-on lab work serves as applied training | N/A |

**Control 14 Overall Status: Limited Applicability — Single-user homelab**

## CIS Control 15: Service Provider Management

| <b>Safeguard</b> | <b>Requirement</b>                                   | <b>Implementation</b>                                                                                                                                                                                                                                                                                                                                                                                                 | <b>Notes</b> |
|------------------|------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|
| <b>15.1</b>      | Establish service provider inventory                 | Cloud providers documented. Updated inventory: AWS (us-east-2, 2 EC2 instances, GuardDuty + Security Hub enabled), Azure (North Central US, 2 VMs, Defender for Cloud + Sentinel enabled), GCP (us-central1, 2 Compute instances, SCC + Cloud Armor enabled), Cloudflare (DNS, Tunnels, CDN, R2), Tailscale (WireGuard mesh VPN, 9 enrolled nodes), PIA (egress VPN). Security posture tools documented per provider. | Compliant    |
| <b>15.2</b>      | Establish service provider management policy (IG2)   | N/A — Single-user lab environment                                                                                                                                                                                                                                                                                                                                                                                     | N/A          |
| <b>15.3</b>      | Classify service providers (IG2)                     | N/A — Single-user lab environment                                                                                                                                                                                                                                                                                                                                                                                     | N/A          |
| <b>15.4</b>      | Ensure contracts include security requirements (IG2) | N/A — Single-user lab environment                                                                                                                                                                                                                                                                                                                                                                                     | N/A          |
| <b>15.5</b>      | Assess service providers (IG3)                       | N/A — Single-user lab environment                                                                                                                                                                                                                                                                                                                                                                                     | N/A          |
| <b>15.6</b>      | Monitor service providers (IG3)                      | N/A — Single-user lab environment                                                                                                                                                                                                                                                                                                                                                                                     | N/A          |
| <b>15.7</b>      | Securely decommission                                | N/A — Single-user lab environment                                                                                                                                                                                                                                                                                                                                                                                     | N/A          |

service providers  
(IG3)

**Control 15 Overall Status: 15.1 Compliant — Service provider inventory expanded to include AWS, Azure, GCP; remainder N/A for single-user lab**

## CIS Control 16: Application Software Security

| Safeguard | Requirement                                              | Implementation                                                                                                                                                                                                                                                                            | Notes                                                               |
|-----------|----------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------|
| 16.1      | Establish secure application development process (IG2)   | Informal — IaC follows security best practices; no formal SDLC documentation. Cloud: ARM templates and Ansible playbooks follow security-by-default patterns; cloud node provisioning IaC reviewed before apply.                                                                          | Gap — Document secure development lifecycle                         |
| 16.2      | Establish vulnerability disclosure process (IG2)         | N/A — Single-user lab environment                                                                                                                                                                                                                                                         | N/A                                                                 |
| 16.3      | Perform root cause analysis on vulnerabilities (IG2)     | Informal — Post-incident reviews conducted; no formal RCA process.                                                                                                                                                                                                                        | Gap — Document RCA procedures                                       |
| 16.4      | Establish third-party software component inventory (IG2) | Partial — Docker images tracked; no comprehensive SBOM tracking. Cloud: cloud node base images (AMIs, GCP images, Azure Marketplace images) tracked by version; no formal SBOM for cloud node packages. Trivy/Grype SBOM implementation planned Q1 2026.                                  | Gap — Implement SBOM tracking (Trivy/Grype); applies to cloud nodes |
| 16.5      | Use up-to-date third-party components (IG2)              | Watchtower auto-updates; WUD monitoring; trusted sources (official Docker images; maintained OSS projects). Cloud: cloud node base OS images kept current via PatchMon/WSUS; provider-maintained base images (Amazon Linux 2, Ubuntu, Debian) used — security patches available same-day. | Compliant                                                           |
| 16.6      | Establish vulnerability severity rating system (IG2)     | CVSS scoring; risk-based prioritization; documented remediation SLAs. Cloud: same CVSS-based severity rating and SLAs applied to cloud node findings from Wazuh, Inspector, SCC, and Defender for Cloud.                                                                                  | Compliant                                                           |
| 16.7      | Use standard hardening templates (IG2)                   | CIS Benchmarks for application infrastructure; IaC templates (Ansible/Terraform); documented configurations. Cloud: same CIS Benchmark hardening templates applied to cloud Linux nodes via Ansible; Wazuh SCA validates compliance                                                       | Compliant                                                           |

|              |                                                  |                                                                                                                                                                                                                                                                                                            |                                                                   |
|--------------|--------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
|              |                                                  | against CIS Amazon Linux, CIS Debian, CIS Ubuntu, and CIS Windows Server 2025 policies.                                                                                                                                                                                                                    |                                                                   |
| <b>16.8</b>  | Separate production/non-production systems (IG2) | N/A — Single-user lab environment                                                                                                                                                                                                                                                                          | N/A                                                               |
| <b>16.9</b>  | Train developers in secure coding (IG2)          | N/A — Single-user lab environment                                                                                                                                                                                                                                                                          | N/A                                                               |
| <b>16.10</b> | Apply secure design principles (IG2)             | Least privilege; input validation; defense-in-depth architecture; secure defaults. Cloud: cloud nodes provisioned with no public management ports (secure default); IAM least-privilege (no wildcard policies); provider-native security services enabled by default (GuardDuty, SCC, Defender for Cloud). | Compliant                                                         |
| <b>16.11</b> | Leverage vetted security modules (IG2)           | Authentik (IAM); Step-CA (PKI); Traefik (reverse proxy); trusted open-source security libraries. Cloud: provider-managed security services used (AWS GuardDuty, GCP SCC, Azure Defender for Cloud) — all are vetted, maintained security modules.                                                          | Compliant                                                         |
| <b>16.12</b> | Implement code-level security checks (IG3)       | Limited — Infrastructure code linting (Ansible-lint/Terraform validate); no comprehensive SAST/DAST. Cloud: Terraform plan review before cloud infrastructure changes applied; no automated SAST scanning of IaC.                                                                                          | Gap — Implement SAST/DAST scanning including IaC scanning         |
| <b>16.13</b> | Conduct application penetration testing (IG3)    | Informal — Vulnerability scanning covers web apps; Kali/Parrot OS pen testing. Cloud: no formal cloud infrastructure penetration testing; vulnerability scanning extended to cloud nodes via Wazuh/Inspector/SCC.                                                                                          | Gap — Formal pen testing (IG3) including cloud scope              |
| <b>16.14</b> | Conduct threat modeling (IG3)                    | Informal — Security architecture design considers threats; no formal STRIDE/DREAD modeling. Cloud: cloud threat model not formally documented; cloud-native threat detection tools (GuardDuty, SCC, Sentinel) provide runtime threat visibility.                                                           | Gap — Document threat models (IG3) including cloud attack surface |

**Control 16 Overall Status: IG2 Mostly Compliant (infrastructure focus); IG3 Partial; cloud scope integrated where applicable**

## CIS Control 17: Incident Response Management

| Safeguard | Requirement | Implementation | Notes |
|-----------|-------------|----------------|-------|
|-----------|-------------|----------------|-------|

|      |                                                 |                                                                                                                                                                                                                                                                                             |           |
|------|-------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 17.1 | Designate incident handling personnel           | N/A — Single-user lab environment                                                                                                                                                                                                                                                           | N/A       |
| 17.2 | Establish contact information for reporting     | Discord channels; SMTP relay; Cloudflare email routing. Cloud: AWS SNS notifications, GCP alerting policy notifications, and Azure Monitor action group (RecommendedAlertRules-AG-1) integrated into notification chain.                                                                    | Compliant |
| 17.3 | Establish enterprise incident reporting process | TheHive case creation process; reporting timeframes defined; multi-channel reporting (Discord, email, API). Cloud: AWS GuardDuty findings and Azure Sentinel incidents automatically create TheHive cases via Shuffle SOAR webhook; GCP SCC findings trigger alerting policy notifications. | Compliant |
| 17.4 | Establish incident response process (IG2)       | Documented IR plan; TheHive playbooks. Cloud node IR: Wazuh Active Response (firewall-drop, host-deny, account-disable) on cloud nodes via Tailscale; AWS Security Group modification for isolation; GCP/Azure firewall rule update for cloud node containment. Runbooks documented.        | Compliant |
| 17.5 | Assign key roles and responsibilities (IG2)     | N/A — Single-user lab environment                                                                                                                                                                                                                                                           | N/A       |
| 17.6 | Define communication mechanisms (IG2)           | Primary: Discord; Secondary: SMTP/Cloudflare email routing; multi-path redundancy. Cloud: AWS SNS, GCP alerting policies, Azure Monitor action group feed Discord/email channels.                                                                                                           | Compliant |
| 17.7 | Conduct routine IR exercises (IG2)              | N/A — Single-user lab environment                                                                                                                                                                                                                                                           | N/A       |
| 17.8 | Conduct post-incident reviews (IG2)             | N/A — Single-user lab environment                                                                                                                                                                                                                                                           | N/A       |
| 17.9 | Establish incident thresholds (IG3)             | Severity matrix documented; CVSS thresholds; Splunk alert severities; MISP threat levels; Prometheus thresholds. Cloud: AWS GuardDuty severity (High/Medium/Low); GCP SCC severity ratings; Azure Sentinel analytics rule severity levels — all mapped to same severity matrix.             | Compliant |

**Control 17 Overall Status: Mostly Compliant; limited IR playbooks and SOAR workflows for both on-premises and cloud workloads.**



## CIS Control 18: Penetration Testing

| Safeguard | Requirement                                       | Implementation                                                                                                                                                                                                                                                                                                                 | Notes                                                                     |
|-----------|---------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| 18.1      | Establish penetration testing program (IG2)       | Informal — Vulnerability scanning exceeds pen testing frequency; no formal pen testing engagement. Cloud: cloud node attack surface is minimal (no public management ports); cloud-native threat detection (GuardDuty, SCC, Defender for Cloud) provides continuous threat detection equivalent to some pen testing functions. | Gap — Document formal pen testing program; cloud nodes should be in scope |
| 18.2      | Perform external penetration tests annually (IG2) | Informal — Weekly OpenVAS/monthly Nessus scans provide partial coverage; no dedicated external pen test. Cloud: cloud public IPs (used only for Tailscale UDP handshake) represent minimal external attack surface; no cloud management ports internet-exposed.                                                                | Gap — Conduct formal external pen test including cloud perimeter          |
| 18.3      | Remediate penetration test findings (IG2)         | Vulnerability remediation process covers pen test findings; documented remediation workflows. Cloud: same remediation SLAs and TheHive tracking applied to any cloud findings from informal testing.                                                                                                                           | Compliant — Process exists                                                |
| 18.4      | Validate security measures post-test (IG3)        | Informal — Re-scanning validates remediation; no formal security control validation.                                                                                                                                                                                                                                           | Gap — Post-remediation validation testing needed                          |
| 18.5      | Perform internal penetration tests annually (IG3) | Informal — No formal internal pen testing. Local scanning, enumeration, and vulnerability testing conducted. Cloud: Kali/Parrot OS available for cloud-scoped internal testing via Tailscale; no formal cloud-internal pen test conducted.                                                                                     | Gap — IG3 requirement; cloud nodes should be included in scope            |

**Control 18 Overall Status: IG2 Partial (vulnerability scanning substitutes); IG3 Not Implemented. Cloud minimal attack surface noted.**

## Summary of Compliance Status

Overall CIS Controls v8.1.2 Compliance — v2.0 (April 2026)

| Implementation Group           | Controls Fully Compliant | Controls Partially Compliant | Controls Not Implemented | Overall Score |
|--------------------------------|--------------------------|------------------------------|--------------------------|---------------|
| IG1 (56 safeguards)            | 52 (93%)                 | 4 (7%)                       | 0 (0%)                   | 93% Compliant |
| IG2 (74 additional safeguards) | 60 (81%)                 | 12 (16%)                     | 2 (3%)                   | 81% Compliant |



|                                       |          |         |         |               |
|---------------------------------------|----------|---------|---------|---------------|
| <b>IG3 (29 additional safeguards)</b> | 15 (52%) | 8 (28%) | 6 (20%) | 52% Compliant |
|---------------------------------------|----------|---------|---------|---------------|

Note: Compliance scores unchanged from v1.0. Cloud integration strengthens evidence for existing compliant safeguards but does not introduce new gaps or close existing open items in IG2/IG3.

Version History

| Version | Date         | Changes                                                                            |
|---------|--------------|------------------------------------------------------------------------------------|
| 1.0     | January 2026 | Initial assessment and summary statistics.                                         |
| 1.1     | March 2026   | Minor updates and formatting corrections.                                          |
| 2.0     | April 2026   | Cloud IaaS integration (AWS, Azure, GCP - 6 nodes total). Cloud content integrated |